

DOM XSS in jQuery Anchor href Attribute Sink Using location.search

Vulnerability

DOM-based Cross-Site Scripting (DOM XSS)

Lab

PortSwigger Web Security Academy

Description

The application was vulnerable to DOM-based XSS because the `returnPath` query parameter from `location.search` was placed into an anchor's `href` attribute without proper validation.

By changing the parameter to a `javascript:` URL, arbitrary JavaScript could be executed when the affected link was clicked.

Steps to Reproduce

1. Navigate to the **Submit feedback** page.
2. Modify the `returnPath` parameter to `/` followed by a random alphanumeric string.
3. Inspect the page element and observe that the value is inserted into the anchor's `href` attribute.
4. Replace the `returnPath` value with:

```
javascript:alert(document.cookie)
```

5. Press **Enter** and click the **Back** link.
6. The JavaScript executes and an alert displays the document cookie.

Payload

```
javascript:alert(document.cookie)
```

Source & Sink

Source: `location.search`

Sink: jQuery-generated anchor `href` attribute

Testing Method

- Burp Suite Repeater
- Browser Developer Tools
- No screenshots available

Impact

An attacker could execute arbitrary JavaScript in the context of the vulnerable application. Depending on the application's functionality and cookie configuration, this could potentially lead to unauthorized actions or exposure of sensitive client-side information.

Remediation

- Do not place untrusted URL parameters directly into `href` attributes.
- Validate URLs against an allowlist of permitted schemes such as `https:.`
- Reject dangerous schemes such as `javascript:.`
- Safely handle user-controlled data before inserting it into the DOM.

OWASP

OWASP Top 10 — A03:2021 Injection

Result

The DOM XSS vulnerability was successfully demonstrated by controlling the `returnPath` parameter and injecting a `javascript:` URL into the anchor's `href` attribute.